

BÁO CÁO CUỐI KHÓA — TRUSTGUARD (FINAL PROJECT)

Tên học viên: Hoàng Quang Thắng

Ngày hoàn thành: 06/05/2026

TRANG 1: COVER & EXECUTIVE SUMMARY

Executive Summary (The Twitter Pitch)

Bọn em là TrustGuard. CISO đang mù tịt về số lượng AI nhân viên lén dùng cho đến khi lộ dữ liệu. TrustGuard tự động hóa duyệt compliance đa mô hình mà không làm chậm Developer. Pilot 3 tập đoàn: duyệt nhanh gấp 5 lần, phát hiện 7 Shadow AI. Gọi \$1M Seed scale 50 Enterprise.

TRANG 2: PITCH MEMO 1-PAGER

1. THE PROBLEM

Hầu hết các doanh nghiệp Enterprise đang chạy đua áp dụng AI, nhưng các Giám đốc/Compliance (CIO/CISO) đang "mù tịt" về việc có bao nhiêu hệ thống AI (đặc biệt là Shadow AI) đang tồn tại trong công ty. Sự thiếu kiểm soát này dẫn đến nguy cơ cực lớn về rò rỉ dữ liệu nhạy cảm và vi phạm luật định (EU AI Act, Data Privacy), khiến họ có thể đối mặt với các án phạt triệu đô.

2. THE INSIGHT

Các công cụ Compliance truyền thống ép Developer phải làm quá nhiều quy trình "giấy tờ" thủ công, dẫn đến sự chống đối ngầm và Shadow AI sinh ra. Insight của chúng tôi: "Cách duy nhất để quản trị rủi ro AI thành công là không làm chậm tốc độ của Developer". Phải biến quy trình Compliance từ một rào cản thành một trạm thu phí tự động (Fast-track).

3. THE SOLUTION

- TrustGuard là một AI Governance Control Tower dành riêng cho Enterprise.
- Differentiator cốt lõi (Workflow Integration Moat):** Thay vì bắt Developer khai báo thủ công, hệ thống tự động phân tích log đa mô hình (OpenAI, Claude, Custom AI) để không chỉ chấm điểm rủi ro mà còn tự động hóa quyết định duyệt compliance (GO/NO-GO). Đây là rào cản quy trình mà Datadog hay công cụ nội bộ của OpenAI không làm được do thiếu tính bao quát và tự động hóa thủ tục pháp lý.
- AI của chúng tôi làm gì? Phân tích log theo thời gian thực để quét dữ liệu nhạy cảm (PII), đo lường rủi ro và tự động hóa luồng ra quyết định GO/NO-GO cho Executive.

4. WHY NOW

GenAI bùng nổ kéo theo lượng AI app nội bộ (nhân viên tự mang vào dùng) tăng gấp 10 lần. Đồng thời, kỷ

nguyên quy định pháp lý về AI (AI Regulations) vừa chính thức bắt đầu. Việc duyệt rủi ro bằng Excel/Docs thủ công hoàn toàn vỡ trận.

5. TRACTION / PROOF

- Đã chạy Pilot thành công tại 3 Tập đoàn lớn (trong đó có VinHomes), kết nối thành công với các pipeline log lớn.
- Phát hiện 7 hệ thống Shadow AI lọt lưới ở tháng đầu tiên.
- Tính năng Fast-track giúp giảm 80% thời gian phê duyệt (từ 10 ngày xuống 2 ngày) cho các dự án AI rủi ro thấp (Low Risk).
- 3 pilot này đã cho kết quả ROI rõ ràng và sẵn sàng convert sang hợp đồng trả phí \$50k/năm. Đã có 10 Enterprise khác đăng ký waitlist.

6. THE ASK

Chúng tôi đang gọi \$1M vòng Seed để scale đội ngũ Enterprise Sales và mở rộng số lượng Integration (kết nối thêm 15 nền tảng Observability) trong 12 tháng tới.

TRANG 3: MARKET ANALYSIS (Cập nhật từ Day 16)

1. Market Size (TAM/SAM/SOM)

Layer	Estimate	Key assumptions
TAM	\$10B+	Global Enterprise Security & GRC (Governance, Risk, Compliance) Tools
SAM	\$1B+	Global Enterprise AI Governance & Security (Ngách đang bùng nổ sau GenAI)
SOM	\$5M+	100 Enterprise lớn tại Việt Nam & SEA x \$50k ACV trong 12-24 tháng tới

2. Moat Hypothesis (Workflow Integration)

Nếu TrustGuard được triển khai rộng rãi, hào nước phòng thủ (Moat) sẽ đến từ:

- **Deep Integration:** Hệ thống đã cắm sâu vào luồng CI/CD và Observability logs của doanh nghiệp. Việc gỡ bỏ là rất tốn chi phí (High Switching Cost).
- **Compliance Workflow:** TrustGuard thay thế quy trình "giấy tờ" của phòng Pháp chế. Đây là rào cản vận hành mà các công cụ thuần tech như Datadog hay dashboard của OpenAI không thể chạm tới.

TRANG 4: CUSTOMER + PAIN STATEMENT

1. Customer / Segment Card

- **Segment name:** CIO / CISO / Head of Compliance tại các tập đoàn lớn (Enterprise).
- **Operational context:** Phải đảm bảo bảo mật dữ liệu và tuân thủ EU AI Act, nhưng nhân viên/dev đang xài GenAI quá nhiều và không kiểm soát nổi.

- **Recurring workflow:** Gửi form Excel/Docs yêu cầu các phòng ban khai báo ứng dụng AI -> Chờ duyệt -> Dev chống đối ngầm vì rườm rà.
- **Pain moment:** Mở dashboard lên phát hiện dữ liệu PII nội bộ đã bị leak qua API của một Shadow AI do nhân viên tự viết.

2. Strategy Statement

- **For** [CISO và C-level],
 - **Who struggle with** [việc nhân viên sử dụng Shadow AI và nguy cơ rò rỉ dữ liệu],
 - **Our product helps them** [tự động phát hiện AI lậu và duyệt rủi ro compliance tự động]
 - **Through** [việc phân tích log đa mô hình từ các nền tảng Observability],
 - **Unlike** [việc khai báo thủ công qua Excel hay các tool Security truyền thống làm chậm dev],
 - **Because we can leverage** [Workflow Integration tự động hoá quyết định GO/NO-GO thay vì chỉ chấm điểm].
-

TRANG 5: PRD SUMMARY + PMF METRIC (Cập nhật từ Day 17)

1. MVP Boundary Sheet

- **Riskiest Assumption:** Liệu các luồng log (LangSmith/Datadog) có đủ chi tiết để AI phân loại rủi ro chính xác và CISO có tin tưởng vào quyết định "Auto GO/NO-GO" của máy thay vì duyệt tay không?
- **In-Scope (NOW):**
 - Quét Log & Phát hiện Shadow AI (Tích hợp LangSmith/DB).
 - Chấm điểm rủi ro Trust Score (PII Scanner).
 - Dashboard tổng quan cho CISO.
- **Out-of-Scope (LATER):**
 - Phân quyền RBAC phức tạp đa tầng.
 - Auto-block cắt API theo thời gian thực (quá rủi ro cho vận hành).

2. PMF Scorecard

- **Aha Moment:** CISO mở dashboard lần đầu tiên và bàng hoàng phát hiện ra 7 ứng dụng Shadow AI đang chạy ngầm trong công ty mà họ không hề hay biết.
 - **Actionable Metric:** % số lượng dự án AI được duyệt tự động (Fast-track) thành công trên tổng số dự án.
 - **Retention Driver:** Báo cáo Trust Score hàng tuần gửi thẳng vào Email/Slack của ban giám đốc.
-

TRANG 6: FINANCIAL MODEL — ASSUMPTIONS (Cập nhật từ Day 18)

1. Mô hình doanh thu (Enterprise B2B SaaS)

- Hình thức thu phí: Thu phí bản quyền phần mềm (Annual License) + Phí Setup (One-time).
- ACV (Annual Contract Value): **\$50,000/năm** cho tập đoàn quy mô lớn.
- Khách hàng mục tiêu trong Year 1: Convert 3 pilot hiện tại + Chốt thêm 7 khách hàng mới (Tổng = 10 Enterprise).
- ARR mục tiêu Year 1: **\$500,000**.

2. Cost Structure

- COGS (Chi phí trực tiếp):** Phí API xử lý log (GPT-4o mini hoặc các mô hình open-source tối ưu chi phí cho quét PII), chi phí Server/Cloud (Azure/AWS).
- OpEx:** Chủ yếu nằm ở đội ngũ Enterprise Sales (chu kỳ bán hàng dài 3-6 tháng) và Solution Architects hỗ trợ tích hợp.

TRANG 7: UNIT ECONOMICS — LTV/CAC/PAYBACK

Do là mô hình Enterprise SaaS, Unit Economics có đặc thù riêng:

- Lifetime Value (LTV):** Dự kiến khách hàng Enterprise sẽ dùng ít nhất 3 năm (do Switching Cost rất cao khi đã tích hợp quy trình compliance).
 - $LTV = 50,000 \times 3 = **150,000**$ (Chưa tính Upsell thêm khối lượng log).
- Customer Acquisition Cost (CAC):** Chi phí trả lương cho Sales B2B, tổ chức hội thảo Security, POC (Proof of Concept) miễn phí.
 - CAC ước tính = **\$10,000 / khách hàng**.
- LTV / CAC Ratio:** $150k / 10k = 15x$ (Cực kỳ khỏe do giá trị hợp đồng lớn và churn rate thấp).
- Payback Period:** Vì khách hàng Enterprise thường trả trước 1 năm (\$50k), Payback Period gần như **ngay lập tức (Tháng thứ 1)** sau khi chốt hợp đồng.

TRANG 8: ROADMAP NOW/NEXT/LATER + OKRs

1. Roadmap (Dựa trên RICE & Vấn đề cần giải)

- NOW:**
 - Giải quyết sự "mù tịt" của CISO về Shadow AI (Tính năng Quét Log).
 - Định lượng rủi ro các model AI (Tính năng Chấm điểm Trust Score).
 - Cung cấp bức tranh toàn cảnh (Tính năng CISO Dashboard).
- NEXT (Strategic Bets):**
 - Loại bỏ sự rườm rà trong compliance cho Dev (Tính năng Fast-track GO/NO-GO tự động).
 - Cảnh báo và phản ứng tự động (Real-time Alert & Auto-block).

- **LATER (Vision):**

- Quản trị quyền hạn chéo chéo khi mở rộng đa quốc gia (RBAC đa tầng).

2. Launch OKRs (Cho Quý tới)

- **Objective:** Trở thành "trạm thu phí" không thể thiếu giúp các tập đoàn dập tắt Shadow AI mà không làm gián đoạn tốc độ kỹ sư.
- **KR1 (Leading - Hành vi):** Tỷ lệ Developer chủ động nộp dự án qua luồng Fast-track của TrustGuard thay vì form Excel đạt trên 80% ngay tuần đầu.
- **KR2 (Lagging - Kết quả):** Ký hợp đồng thương mại (MRR \$4,000/khách hàng) thành công với 3/3 khách hàng Pilot hiện tại.
- **KR3 (Quality - Chất lượng):** Net Promoter Score (NPS) đo lường từ CISO và team Pháp chế đạt mức > 60 sau 30 ngày sử dụng.

TRANG 9: DEPENDENCY MAP + CRITICAL PATH

1. Sơ đồ phụ thuộc (Dependencies - Top 3 rủi ro giết dự án)

Dependency 1: OpenAI/LLM API rate limit & policy thay đổi

Worst-case: OpenAI đột ngột khóa tài khoản API hoặc cấm dùng LLM của họ để "giám sát" (monitor) hệ thống khác.

Plan B: Viết sẵn abstraction layer. Chuyển đổi sang dùng LLM mã nguồn mở (như Llama 3) tự host trên cloud khách hàng để quét PII nội bộ trong vòng 24h.

Cost: 2 tuần dev để dựng sẵn Llama 3 fallback (Sẽ làm ngay trong sprint tới).

Dependency 2: Nền tảng Observability (Datadog/LangSmith) đổi cấu trúc API

Worst-case: Datadog đổi schema API hoặc tính phí quá cao cho việc pull log lượng lớn, làm gián đoạn luồng quét rủi ro.

Plan B: Build một SDK gọn nhẹ (Standard Log Format) để khách hàng tự đẩy log (Push) thay vì TrustGuard phải kéo log (Pull).

Cost: 3 tuần dev cho bộ SDK cơ bản + 1 tuần hỗ trợ khách hàng đổi luồng.

Dependency 3: Quy định pháp lý Enterprise (Legal / Data Privacy)

Worst-case: Bộ phận Pháp chế (Legal) của tập đoàn từ chối cho phép một Third-party SaaS đọc log nhạy cảm của nhân viên.

Plan B: Cung cấp phiên bản On-premise deployment hoặc mã hóa dữ liệu đầu cuối (End-to-End Encryption) mà TrustGuard chỉ lấy metadata chấm điểm.

Cost: 4 tuần dev cấu hình hạ tầng On-prem + Phí thuê Audit bảo mật độc lập.

2. Critical Path (Đường găng)

- (1) Xin phê duyệt Legal Compliance từ CISO ->
- (2) Thiết lập Abstraction Layer cho LLM ->
- (3) Tích hợp luồng Log (Datadog/LangSmith) ->
- (4) Xây dựng Logic Chấm Trust Score ->
- (5) Giao diện CISO Dashboard (Song song với UI) ->
- (6) Luồng phê duyệt tự động (Fast-track)

Ghi chú:

- Nút thắt nguy hiểm nhất trên Critical Path là **(1) Legal Compliance**. Nếu Pháp chế không duyệt cho đọc log, mọi tính năng kỹ thuật sau đó vô nghĩa.
- UI Design / Marketing nằm ngoài đường găng, có thể chạy song song.

Phụ lục:

Link đến file PRD Day 17: https://github.com/hqt0810-lab/GD2-track-1/tree/main/Day17_Hoang-Quang-Thang_2A202600069

Link đến file Excel Day 18: <https://github.com/hqt0810-lab/GD2-track-1/blob/main/Day18-AI-Product-Finance-Model.xlsx>